



تقرير الأمان والحماية

منظومة وصلّي — فحص أمني عميق وشامل

فحص كامل لكل طبقات الحماية: المصادقة، الصلاحيات، حقن قواعد البيانات،
الثغرات، الأسرار، ورفع الملفات — مع الإصلاحات المطبّقة.

تم إجراء فحص أمني عميق لكامل السيرفر. النتيجة: المنظومة محمية بمستوى عالٍ جدًا — الطبقات الأساسية كلها موجودة وسليمة، ولم يُعثَر على ثغرات حرجية قابلة للاختراق. تم أيضًا تطبيق تحصين إضافي (Defense in Depth) لرفع المستوى أكثر.

التقييم العام

المجال	الحالة
حقن قواعد البيانات (SQL Injection)	محمي بالكامل ✓
المصادقة وكلمات المرور	قوي ✓
الصلاحيات والوصول (IDOR)	محمي ✓
حماية التخمين والإغراق (Brute-force / DoS)	موجود ✓
الأسرار والمفاتيح	لا تسريب ✓
رفع الملفات	آمن ✓
تسريب معلومات الأخطاء	تم تحصينه الآن ✓

تقرير وصلّي — الأمان

المصادقة (Authentication) سليم

كلمات المرور مشفرة بـ **bcrypt** (لا تُخزن كنص ولا يمكن استرجاعها). الدخول عبر **JWT** موقع بمفتاح سرّي (مضبوط بمتغيّر بيئة، غير مكشوف). كل طلب يتحقق أن الحساب **فَعَال** و**غير محظور**. لا يتم إرجاع كلمة المرور المشفرة في أي رد.

حقن قواعد البيانات (SQL Injection) محمي

كل الاستعلامات تستخدم معاملات آمنة (**Parameterized \$1,\$2**). حتى الاستعلامات الديناميكية (أسماء الأعمدة) مبنية من **قوائم بيضاء ثابتة** — لا مدخلات مستخدم تدخل نص الاستعلام. لا توجد ثغرة حقن.

الصلاحيات والوصول (IDOR / Authorization) محمي

فصل صلاحيات كامل حسب الدور (زبون / سائق / مطعم / إدارة). تفاصيل كل طلب لا يراها إلا صاحبه أو السائق المعيّن أو صاحب المطعم أو الإدارة. تعديل الطلبات محصور بالجهة المخوّلة فقط. المطاعم تتحقق من ملكية العناصر قبل أي تعديل.

الحماية ضد التخمين والإغراق موجود

حدّ معدّل طلبات لكل IP (مشارك عبر Redis عند التوسّع). عدّاد محاولات دخول فاشلة يقفل مؤقتًا بعد محاولات متكررة (Brute-force). حدّ إرسال رموز التحقق (OTP).

الأسرار والمفاتيح لا تسريب

لا توجد أي مفاتيح أو أسرار مرفوعة على Git (تم التأكد). ملفات الأسرار (مفاتيح .env / APNs / Firebase) مستثناة بالكامل. لا مفاتيح مكتوبة داخل الكود. الاتصال كله عبر **HTTPS مشفّر**.

رفع الملفات آمن

يُقبل الصور فقط (فحص نوع)، ثم تُعاد معالجتها بالكامل (تحوّل وتُضغط) — ما يزيل أي كود خبيث مخبأ داخل الصورة. حدّ لحجم الملف. التخزين الآن على CDN خارجي.

✓ إخفاء تفاصيل أخطاء السيرفر

أضيف حاجز مركزي يمنع تسريب أي تفاصيل داخلية للأخطاء (5xx) للعميل في الإنتاج — يُرجع فقط رسالة عامة، فلا يستفيد أي مهاجم من رسائل الأخطاء للاستكشاف.

✓ منع تكرار الإشعارات + عزل التوكنات

(سابقًا) تم إصلاح تسريب/تكرار توكنات الإشعارات بحيث كل توكن يخص حسابًا واحدًا فقط.

✓ رؤوس حماية (Helmet) HTTP + ضغط + HTTPS

رؤوس أمان قياسية مفعلة على كل الردود، وإخفاء بصمة الخادم.

توصيات مستقبلية (عند التوسع لعدة نسخ)

التوصية	الفائدة
نقل عدّاد التخمين إلى Redis	حماية موحدة عبر كل النسخ عند التشغيل بعدة سيرفرات
مراجعة أمنية دورية (كل بضعة أشهر)	ضمان استمرار الحماية مع إضافة ميزات جديدة
نسخ احتياطي مجدول لقاعدة البيانات	استرجاع سريع عند أي طارئ
مراقبة وتنبيهات (Monitoring)	كشف أي نشاط غير طبيعي فورًا

النتيجة النهائية: منظومة وصلي آمنة بمستوى عالٍ جدًا، لا توجد ثغرات حرجة، وتم رفع مستوى التحصين أكثر. الأمان عملية مستمرة — مع كل ميزة جديدة يُنصح بمراجعة سريعة للحفاظ على نفس المستوى.

تقرير وصلي — الأمان والحماية · نهاية التقرير